SecureTech Solutions: Vulnerability Assessment and Compliance Audit Report

Generated 2026-10-27 05:30 UTC. Simulated organization. Lab environment only.

1. Executive summary

SecureTech Solutions was assessed as a simulated 60-employee organization. The assessment found 24 open technical findings, of which 15 are priority P1 or P2. The security posture score is **33/100 (Critical)**. Compliance status: 7 of 8 control areas are non-compliant and 1 are partially compliant.

The most urgent actions are to remove the vsftpd 2.3.4 backdoor, fix the SQL injection on the employee web portal, and disable or restrict the VNC, rsh, rlogin, X11, Samba and AJP services. Anonymous FTP, Telnet and password-free sudo have already been fixed on the company server.

2. Organization profile

SecureTech Solutions: 60 employees in five departments (Management 5, HR 5, Finance 8, IT 8, Employees 34). Lab network 192.168.56.0/24 (VirtualBox host-only). Auditor: Kali Linux (192.168.56.4). Company server: Metasploitable 2 (192.168.56.10). Employee web portal: OWASP Juice Shop (192.168.56.1:3000).

ID	Asset	Department	Classification	Criticality	Exposure	Lab implementation
AST-001	Executive laptops (5)	Management	Confidential	5	Internal	Simulated record
AST-002	Board and strategy document share	Management	Confidential	5	Internal	Simulated record
AST-003	HR workstations (5)	HR	Confidential	4	Internal	Simulated record
AST-004	Employee personnel records	HR	Restricted	5	Internal	File share on company server
AST-005	Payroll data	HR / Finance	Restricted	5	Internal	File share on company server

ID	Asset	Department	Classification	Criticality	Exposure	Lab implementation
AST-006	Finance workstations (8)	Finance	Confidential	4	Internal	Simulated record
AST-007	Accounting records and bank payment files	Finance	Restricted	5	Internal	File share on company server
AST-008	IT workstations (8)	IT	Confidential	4	Internal	Simulated record
AST-009	Company internal server	IT	Restricted	5	Internal	Metasploitable 2 VM (UTM)
AST-010	Backup storage	IT	Restricted	4	Internal	Simulated record
AST-011	Network infrastructure (router, switch)	IT	Confidential	4	Internal	Simulated record
AST-012	Employee web portal	Employees (all)	Confidential	4	Remote	Juice Shop container, 192.168.56.1:3000
AST-013	Source code repository	Employees (Developers)	Restricted	5	Internal	Directory /srv/repo on company server
AST-014	CRM and customer records	Employees (Sales)	Confidential	4	Internal	Simulated record
AST-015	Support ticket system	Employees (Support)	Internal	3	Internal	Simulated record
AST-016	Employee workstations (34)	Employees	Internal	3	Internal	Simulated record
AST-017	Operations shared drive	Employees (Operations)	Internal	3	Internal	Directory /srv/operations on company server

3. Methodology

Host discovery and service detection with Nmap (`-sV`), web security checks with Nmap HTTP scripts and curl, password audit with John the Ripper on lab accounts, and a plaintext traffic capture with tcpdump.

Each finding is linked to evidence in the project's evidence folder. Risk is calculated as described in section 5.

4. Findings

ID	Vuln	Asset	Finding	CVSS	Risk	Priority	Status	Remediation
27		AST-009	Exposed service: 8009/tcp (ajp13)	9.8	7.8	P1	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
20		AST-009	Exposed service: 445/tcp (netbios-ssn)	9.8	7.8	P1	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
19		AST-009	Exposed service: 139/tcp (netbios-ssn)	9.8	7.8	P1	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
1	VUL-002	AST-009	vsftpd 2.3.4 contains a known backdoor	9.8	7.8	P1	Open	Remove FTP or replace vsftpd with a supported release. Version 2.3.4 is known to contain a backdoor.
26		AST-009	Exposed service: 6000/tcp (X11)	9.1	7.3	P1	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
22		AST-009	Exposed service: 514/tcp (shell)	9.1	7.3	P1	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
21		AST-009	Exposed service: 513/tcp (login)	9.1	7.3	P1	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
10	VUL-009	AST-012	SQL injection on the login endpoint	9.1	7.3	P1	Open	Use parameterized queries, validate input, and give the database account least privilege.
4	VUL-001	AST-009	Unnecessary VNC service exposed on port 5900	9.1	7.3	P1	Open	Disable VNC, or require strong authentication and limit access to the admin network.

ID	Vuln	Asset	Finding	CVSS	Risk	Priority	Status	Remediation
25		AST-009	Exposed service: 5432/tcp (postgresql)	8.8	7.0	P1	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
6	VUL-005	AST-009	Weak passwords on employee accounts	8.8	7.0	P1	Open	Enforce a password policy, reset the affected accounts, and enable MFA.
24		AST-009	Exposed service: 2121/tcp (ftp)	8.1	6.5	P2	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
7	VUL-006	AST-009	helpdesk01 has full root without a password	7.8	6.2	P2	Resolved	Remove the NOPASSWD rule and grant only the commands the role needs.
23		AST-009	Exposed service: 2049/tcp (nfs)	7.5	6.0	P2	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
12	VUL-012	AST-012	Sensitive files exposed under /ftp, including a password database	7.5	6.0	P2	Open	Remove sensitive files from public paths and disable directory listing.
5	VUL-003	AST-009	Outdated Apache, MySQL and OpenSSH versions	7.5	6.0	P2	Open	Upgrade Apache, MySQL and OpenSSH to supported versions, or replace the server.
2	VUL-004	AST-009	Anonymous FTP login is enabled	7.5	6.0	P2	Resolved	Set anonymous_enable=NO in vsftpd.conf and restart vsftpd.
3	VUL-001	AST-009	Telnet exposes cleartext logins (also VUL-014)	6.5	5.2	P2	Resolved	Disable Telnet and use SSH with key authentication.
13	VUL-010	AST-012	DOM cross-site scripting in product search	6.1	4.9	P3	Open	Encode output, sanitize user input, and add a Content-Security-Policy.
17		AST-009	Exposed service: 53/tcp (domain)	5.9	4.7	P3	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
9	VUL-008	AST-013	Source code repository is readable by all users	5.5	4.4	P3	Open	Restrict /srv/repo to the development group (chmod 750).

ID	Vuln	Asset	Finding	CVSS	Risk	Priority	Status	Remediation
18		AST-009	Exposed service: 111/tcp (rpcbind)	5.3	4.2	P3	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
16		AST-009	Exposed service: 25/tcp (smtp)	5.3	4.2	P3	Open	Confirm the service is required. If it is not, stop it or block the port on the host firewall.
11	VUL-011	AST-012	Admin configuration readable without login	5.3	4.2	P3	Open	Enforce server-side authorization on all administrative endpoints.
15	VUL-013	AST-009	Missing security headers on the company server	4.3	3.4	P3	Open	Set X-Frame-Options, X-Content-Type-Options and Content-Security-Policy in Apache.
14	VUL-013	AST-012	Missing Content-Security-Policy header on the web portal	4.3	3.4	P3	Open	Add a Content-Security-Policy header.
8	VUL-007	AST-017	Shared staff group gives HR and Finance access to Operations data	5.5	2.6	P4	Open	Remove HR and Finance from the shared group and restrict the Operations drive to its members.

5. Risk method

Each finding is scored with CVSS v3.1 base metrics. The vector for each finding is listed in the evidence folder. Risk = CVSS base score x (asset criticality / 5) x exposure factor. Exposure factor: Remote 1.0, Internal 0.8. CVSS already includes how easy the attack is, so no separate exploitability factor is applied, which avoids counting it twice. Priority: P1 at 7.0 or above, P2 at 5.0 or above, P3 at 3.0 or above, P4 below 3.0. Likelihood and impact (1-5) are recorded for each finding but are not part of the formula.

Posture = 100 x (1 - open risk / total maximum risk). Each finding's risk is its CVSS v3.1 base score x (asset criticality / 5) x exposure factor. Its maximum is CVSS 10 on the same asset. Resolved findings still count toward the maximum, so fixing a finding raises the score. This is a prototype indicator, not a certified security rating.

6. Compliance audit (CIS Controls v8)

Control area	CIS mapping	Status	Evidence	Recommended action
Password security	Control 5 (5.2), Control 6 (6.3, 6.5)	Non-compliant	VUL-005; POL-001	Enforce a password policy and enable MFA for staff and privileged accounts.
Access control	Control 6 (6.1, 6.8)	Non-compliant	VUL-006; VUL-007	Remove the NOPASSWD rule and the shared group; review access quarterly.
Patch management	Control 7 (7.3)	Non-compliant	VUL-002; VUL-003; POL-005	Adopt a monthly patch cycle and replace end-of-life software.
Network security	Control 4 (4.8), Control 12 (12.2)	Non-compliant	VUL-001; VUL-004	Disable Telnet, anonymous FTP and VNC; restrict services to required ports.
Data protection	Control 3 (3.1, 3.3)	Partially compliant	VUL-008; VUL-012; POL-006	Enforce the data classification already in the organization record and restrict Restricted data.
Backup	Control 11 (11.2)	Non-compliant	POL-002	Define a daily backup schedule for Restricted data and test restores quarterly.
Security monitoring	Control 8 (8.2, 8.11)	Non-compliant	POL-003	Centralize logs and review authentication and privilege events weekly.
Incident response	Control 17 (17.4)	Non-compliant	POL-004	Write an incident-response plan with contacts and test it annually.

7. Services on the company server (last scan)

Port	Protocol	Service	Version	Scanned
22	tcp	ssh	4.7p1 Debian 8ubuntu1	2026-10-27T05:13:46.969216+00:00
25	tcp	smtp		2026-10-27T05:13:46.969216+00:00
53	tcp	domain	9.4.2	2026-10-27T05:13:46.969216+00:00
80	tcp	http	2.2.8	2026-10-27T05:13:46.969216+00:00
111	tcp	rpcbind	2	2026-10-27T05:13:46.969216+00:00
139	tcp	netbios-ssn	3.X - 4.X	2026-10-27T05:13:46.969216+00:00

Port	Protocol	Service	Version	Scanned
445	tcp	netbios-ssn	3.X - 4.X	2026-10-27T05:13:46.969216+00:00
513	tcp	login		2026-10-27T05:13:46.969216+00:00
514	tcp	shell		2026-10-27T05:13:46.969216+00:00
2049	tcp	nfs	2-4	2026-10-27T05:13:46.969216+00:00
2121	tcp	ftp	1.3.1	2026-10-27T05:13:46.969216+00:00
3306	tcp	mysql	5.0.51a-3ubuntu5	2026-10-27T05:13:46.969216+00:00
5432	tcp	postgresql	8.3.0 - 8.3.7	2026-10-27T05:13:46.969216+00:00
5900	tcp	vnc		2026-10-27T05:13:46.969216+00:00
6000	tcp	X11		2026-10-27T05:13:46.969216+00:00
8009	tcp	ajp13		2026-10-27T05:13:46.969216+00:00

8. Remediation and posture over time

Posture = 100 x (1 - open risk / total maximum risk). Each finding's risk is its CVSS v3.1 base score x (asset criticality / 5) x exposure factor. Its maximum is CVSS 10 on the same asset. Resolved findings still count toward the maximum, so fixing a finding raises the score. This is a prototype indicator, not a certified security rating.

Snapshot	Score	Rating	Open findings	Taken
After remediation	33	Critical	24	2026-10-27T05:13:46.977463+00:00
Before remediation	25	Critical	27	2026-10-27T05:13:16.631428+00:00

Remediation items are listed in the Remediation column of section 4. Items marked Resolved were fixed on the company server and re-tested.

9. Limitations

- This is a lab assessment of a simulated organization. Findings are not a certified rating.

- CVSS v3.1 base scores are computed from each finding's vector. The vectors for the scanner-found services are assessments (see Docs/risk_scoring.md, section 1.2), not NVD entries for the exact versions detected.
- Web testing used Nmap HTTP scripts and curl. OWASP ZAP and Burp Suite were not used.
- The company server is intentionally vulnerable and is isolated from other networks.